Cyber Security

Chapter 1: Basic Cyber Security Concepts

1.1 Introduction to Cyber Security

Cyber Security is the practice of protecting computers, networks, systems, and data from unauthorized access, attacks, damage, or theft.

Cyber Security → Protects computers, networks, and data.

Example

A company uses:

Passwords

Firewalls

Antivirus

Multi-Factor Authentication (MFA)

to protect its systems and data.

1.2 Information Security

Information Security means protecting information from unauthorized access, modification, disclosure, or destruction.

The main goals are:

Confidentiality – Only authorized people can access information.

Integrity – Information remains correct and unchanged.

Availability – Information is available when needed.

These three are called the CIA Triad.

Example

For a bank account:

Confidentiality → Only you can see your account.

Integrity → Your balance cannot be changed illegally.

Availability → You can access your account when needed.

CIA → Confidentiality, Integrity, Availability

1.3 Threat, Vulnerability and Attack

Threat:A possible danger to a system.

Vulnerability:A weakness in a system.

Attack:An attempt to use a vulnerability to cause harm.

Example

Weak Password

↓

Vulnerability

Attacker tries to guess it

↓

Attack

Unauthorized access

↓

Result

■ Chapter 1 – Quick Revision

Cyber Security:Protects computers, networks, systems, and data.

Confidentiality:Protects information from unauthorized access.

Integrity:Keeps information correct and unchanged.

Availability:Makes information available when needed.

Threat:Possible danger.

Vulnerability:Weakness in a system.

Attack:An attempt to exploit a weakness.

■ Remember

CIA → Confidentiality + Integrity + Availability

Chapter 2: Information Security Terminology

2.1 Asset

An asset is anything valuable that needs protection.

Examples:

Data

Computers

Servers

Networks

Applications

Asset → Something valuable that needs protection.

2.2 Authentication

Authentication is the process of verifying who a user is.

Example

Logging into an account using:

Username + Password

Authentication → Who are you?

2.3 Authorization

Authorization determines what an authenticated user is allowed to do.

Example

A normal employee may read a file, while an administrator may read and modify it.

Authorization → What are you allowed to do?

2.4 Encryption

Encryption converts readable data into an unreadable form to protect it.

Plaintext

↓

Encryption

↓

Ciphertext

The data can later be converted back using decryption.

Encryption → Protects data by converting it into an unreadable form.

2.5 Malware

Malware means Malicious Software.

It is software designed to harm a computer, steal information, or perform unauthorized activities.

Examples:

Virus

Worm

Trojan

Ransomware

Spyware

Malware → Software designed to cause harm or perform unauthorized actions.

■ Chapter 2 – Quick Revision

Asset: Something valuable that needs protection.

Authentication: Verifies identity.

Authorization: Determines permissions.

Encryption: Converts readable data into an unreadable form.

Malware: Malicious software.

■ Remember

Authentication → Who are you?

Authorization → What can you do?

Chapter 3: Malware Classifications and Types

3.1 Introduction to Malware

Malware is software created to damage systems, steal information, or perform unauthorized activities.

3.2 Virus

A Virus is malware that attaches itself to a file or program and spreads when the infected file is executed.

Virus → Attaches to another file or program.

3.3 Worm

A Worm is malware that can spread from one computer to another without requiring a user to run an infected file.

Worm → Spreads automatically between systems.

3.4 Trojan

A Trojan is malicious software that appears to be a legitimate or useful program.

Example

A user downloads a fake application, but the application contains malicious code.

Trojan → Looks legitimate but performs malicious actions.

3.5 Ransomware

Ransomware is malware that prevents access to files or systems and demands payment from the victim.

Ransomware → Locks or encrypts data and demands payment.

3.6 Spyware

Spyware is malware that secretly collects information about a user or system.

Spyware → Secretly collects information.

■ Chapter 3 – Quick Revision

Virus: Attaches to files or programs.

Worm: Spreads automatically.

Trojan: Looks like legitimate software.

Ransomware: Locks/encrypts data and demands payment.

Spyware: Secretly collects information.

■ Remember

Virus → Attaches

Worm → Spreads

Trojan → Pretends

Ransomware → Locks

Spyware → Watches/Collects

Chapter 4: Server-Side Web Application Attacks

4.1 Introduction

A server-side attack targets the web application or server rather than only the user's browser.

Web applications often receive data from users. If the application does not properly validate or process this data, attackers may exploit it.

Server-Side Attack → Targets the application or server.

4.2 Common Server-Side Attacks

Common examples include:

SQL Injection

Authentication attacks

Command Injection

Server-Side Request Forgery (SSRF)

These attacks may allow attackers to access data, execute unauthorized actions, or affect the server.

4.3 Basic Protection

Web applications can be protected by:

Validating input

Using secure authentication

Applying least privilege

Keeping software updated

Using secure coding practices

Secure Input → Secure Application

■ Chapter 4 – Quick Revision

Server-Side Attack:An attack that targets a web application or server.

Common attacks:SQL Injection, Command Injection, Authentication attacks, SSRF.

Protection:Input validation, secure authentication, least privilege, updates, and secure coding.

Chapter 5: Cross-Site Scripting (XSS)

5.1 Introduction to XSS

Cross-Site Scripting (XSS) is a web security attack in which an attacker causes malicious script to run in another user's browser.

XSS → Malicious script runs in a user's browser.

5.2 Simple Example

Suppose a website displays user comments without properly checking them.

An attacker submits malicious script instead of a normal comment.

When another user opens the page, the browser may execute the script.

Attacker

↓

Malicious Input

↓

Web Application

↓

Victim's Browser

↓

Script Executes

5.3 Types of XSS

Common types are:

Stored XSS – Malicious script is stored on the server.

Reflected XSS – Malicious input is immediately returned by the application.

DOM-Based XSS – The vulnerability occurs through client-side JavaScript and the DOM.

5.4 Protection Against XSS

Validate input.

Encode output.

Use secure coding practices.

Use Content Security Policy (CSP) where appropriate.

XSS Protection → Validate input and safely encode output.

■ Chapter 5 – Quick Revision

XSS:Causes malicious script to run in a user's browser.

Stored XSS:Script is stored by the application.

Reflected XSS:Script is reflected back in the response.

DOM-Based XSS:Occurs through client-side manipulation of the DOM.

Chapter 6: SQL Injection

6.1 Introduction to SQL Injection

SQL Injection is an attack in which malicious input is inserted into an application's SQL query.

It can allow an attacker to access or modify database information.

SQL Injection → Malicious input affects a database query.

6.2 Simple Example

Suppose a login system creates a database query using user input without proper protection.

Username → User Input

Password → User Input

↓

Application

↓

Database Query

If input is not handled safely, an attacker may manipulate the query.

6.3 Effects of SQL Injection

SQL Injection may allow an attacker to:

Read data.

Modify data.

Delete data.

Bypass authentication in vulnerable applications.

6.4 Protection Against SQL Injection

The main protection is to use parameterized queries (prepared statements).

Other protections include:

Input validation

Least-privilege database accounts

Secure coding

Proper error handling

SQL Injection Protection → Use parameterized queries.

■ Chapter 6 – Quick Revision

SQL Injection:An attack that manipulates SQL queries through malicious input.

Possible effects:Read, modify, or delete database information.

Main protection:Parameterized queries/prepared statements.

Chapter 7: Cross-Site Request Forgery (CSRF)

7.1 Introduction to CSRF

Cross-Site Request Forgery (CSRF) is an attack that tricks an authenticated user into sending an unwanted request to a web application.

CSRF → Tricks a user into performing an unwanted action.

7.2 Simple Example

A user is logged into an online banking website.

The attacker tricks the user into visiting a malicious page.

The page causes the user's browser to send a request to the banking website.

User Logged In

↓

Malicious Website

↓

Unwanted Request

↓

Target Website

7.3 Protection Against CSRF

Common protections include:

CSRF tokens

SameSite cookies

Checking request origin where appropriate

CSRF Protection → Use CSRF tokens and secure cookie settings.

■ Chapter 7 – Quick Revision

CSRF:Tricks an authenticated user into sending an unwanted request.

Protection:CSRF tokens and secure cookie settings such as SameSite.

Chapter 8: Planning and Security Policy

8.1 Introduction to Security Planning

Security Planning is the process of deciding how an organization will protect its systems, networks, and information.

It includes identifying:

Assets

Threats

Risks

Security controls

Security Planning → Decides how to protect an organization.

8.2 Security Policy

A Security Policy is a set of rules that defines how an organization protects and uses its information systems.

Example

A company policy may require:

Strong passwords

MFA

Regular backups

Limited access to sensitive data

Security Policy → Defines security rules for an organization.

8.3 Risk

Risk is the possibility of loss or damage caused by a threat exploiting a vulnerability.

Threat + Vulnerability

↓

Risk

↓

Possible Damage

■ Chapter 8 – Quick Revision

Security Planning:Plans how to protect systems and information.

Security Policy:Defines security rules.

Risk:Possibility of loss or damage.

■ Remember

Asset → What we protect

Threat → What can cause harm

Vulnerability → Weakness

Risk → Possible loss

Control → Protection

Chapter 9: Network Protocols and Service Models

9.1 Network Protocol

A network protocol is a set of rules used by devices to communicate with each other.

Examples:

HTTP

HTTPS

DNS

FTP

TCP

IP

Protocol → Rules for communication.

9.2 Service Model

A service model describes how a network service is provided and used.

In cloud computing, common service models are:

IaaS – Infrastructure as a Service

PaaS – Platform as a Service

SaaS – Software as a Service

Example

IaaS → Virtual Machines

PaaS → Application Platform

SaaS → Ready-to-use Software

■ Chapter 9 – Quick Revision

Network Protocol:Rules used for communication.

IaaS: Infrastructure as a Service.

PaaS: Platform as a Service.

SaaS: Software as a Service.

Chapter 10: Transport Layer Security

10.1 Introduction to TLS

Transport Layer Security (TLS) is a security protocol used to protect communication over a network.

It provides:

Confidentiality

Integrity

Authentication

TLS → Protects data during network communication.

10.2 HTTPS

HTTPS uses HTTP over a secure TLS connection.

HTTP

↓

TLS

↓

HTTPS

When you visit:

https://example.com

the connection can use TLS to protect the communication.

10.3 Basic TLS Process

Client

↓

TLS Handshake

↓

Server Authentication

↓

Secure Connection

↓

Encrypted Communication

TLS → Establishes a secure communication channel.

■ Chapter 10 – Quick Revision

TLS:Protects network communication.

HTTPS:HTTP secured using TLS.

TLS provides:Confidentiality, Integrity, and Authentication.

Chapter 11: Network Layer Security

11.1 Introduction to Network Layer Security

Network Layer Security protects communication at the network layer.

A common technology is IPsec (Internet Protocol Security).

IPsec → Protects IP communication.

11.2 IPsec

IPsec is a collection of protocols used to secure IP communications.

It can provide:

Authentication

Integrity

Confidentiality

IPsec is commonly used in Virtual Private Networks (VPNs).

Simple Flow

Device A

↓

IPsec/VPN

↓

Secure Network

↓

IPsec/VPN

↓

Device B

11.3 VPN

A Virtual Private Network (VPN) creates a protected connection over a public network.

VPN → Creates a secure connection over an untrusted/public network.

■ Chapter 11 – Quick Revision

Network Layer Security:Protects network-layer communication.

IPsec:Security protocols for IP communication.

VPN:Creates a protected connection over a public network.

Chapter 12: Wireless Security

12.1 Introduction to Wireless Security

Wireless Security protects wireless networks from unauthorized access and attacks.

Wireless networks use technologies such as Wi-Fi.

12.2 Common Wireless Security Standards

Common Wi-Fi security technologies include:

WPA – Wi-Fi Protected Access

WPA2

WPA3

WPA3 provides stronger security than older wireless security methods.

Wireless Security → Protects Wi-Fi networks and wireless communication.

12.3 Wireless Security Practices

Use WPA2 or WPA3.

Use strong passwords.

Change default administrator credentials.

Keep wireless devices updated.

Use a separate guest network when appropriate.

■ Chapter 12 – Quick Revision

Wireless Security:Protects wireless networks.

WPA:Wi-Fi Protected Access.

WPA2/WPA3:Wireless security standards.

■ Remember

WPA3 → Stronger modern Wi-Fi security

Chapter 13: Cloud Security

13.1 Introduction to Cloud Security

Cloud Security means protecting cloud systems, applications, networks, and data.

Cloud Security → Protects resources and data in cloud environments.

13.2 Common Cloud Security Measures

Identity and Access Management (IAM)

Multi-Factor Authentication (MFA)

Encryption

Network security

Monitoring

Backup and recovery

13.3 Shared Responsibility

In cloud computing, security responsibilities are shared between the cloud provider and the customer.

Cloud Provider

+

Customer

↓

Cloud Security

The exact responsibility depends on the service model.

For example, the customer is generally responsible for protecting its accounts, data, identities, and configurations.

Shared Responsibility → Cloud security is shared between provider and customer.

■ Chapter 13 – Quick Revision

Cloud Security:Protects cloud systems and data.

Common protections:MFA, encryption, IAM, network security, monitoring, and backups.

Shared Responsibility:Security responsibilities are shared between the provider and customer.

Chapter 14: IoT Security

14.1 Introduction to IoT Security

IoT (Internet of Things) Security means protecting Internet-connected devices and their data from unauthorized access and attacks.

Examples of IoT devices:

Smart cameras

Smart watches

Smart sensors

Smart appliances

IoT Security → Protects connected smart devices and their data.

14.2 Common IoT Security Problems

IoT devices may have problems such as:

Weak passwords

Outdated software

Poor security configuration

Unnecessary network access

Lack of encryption

14.3 IoT Security Measures

IoT devices can be protected by:

Using strong passwords.

Changing default credentials.

Updating firmware.

Using encryption.

Limiting network access.

Monitoring devices.

IoT Security → Secure the device, software, network, and data.

■ Chapter 14 – Quick Revision

IoT Security:Protects connected devices and their data.

Common Problems:Weak passwords, outdated software, poor configuration, and unnecessary access.

Protection:Strong passwords, updates, encryption, limited access, and monitoring.

■ Remember

IoT Security

↓

Device + Software + Network + Data

■ Overall Cyber Security Quick Revision

Topic

Simple Meaning

Cyber Security

Protects computers, networks, and data

CIA Triad

Confidentiality, Integrity, Availability

Malware

Malicious software

Virus

Attaches to files/programs

Worm

Spreads automatically

Trojan

Pretends to be legitimate software

Ransomware

Locks/encrypts data and demands payment

Spyware

Secretly collects information

XSS

Malicious script runs in a user's browser

SQL Injection

Manipulates database queries

CSRF

Tricks an authenticated user into an unwanted action

TLS

Protects network communication

IPsec

Secures IP communication

VPN

Creates a protected network connection

Wireless Security

Protects Wi-Fi networks

Cloud Security

Protects cloud resources and data

IoT Security

Protects connected smart devices

■ Most Important Things to Remember

CIA

↓

Confidentiality

Integrity

Availability

Authentication → Who are you?

Authorization → What can you do?

Threat → Possible danger

Vulnerability → Weakness

Attack → Attempt to exploit weakness

Risk → Possible loss

Control → Protection

XSS → Attacks the user's browser

SQL Injection → Attacks database queries

CSRF → Tricks an authenticated user

TLS → Secure communication

IPsec → Secure IP communication

VPN → Protected network connection